Care Access Navigator

Incident Response 1 — Task 6: Post-Incident Procedures

Environment and system recovery, root cause analysis, a tested recovery validation checklist, and IR process improvements for IR1-2026-002

Document ID	CAN-IR1-T6-POST-002
Author	Akhila Chennamaneni
Date	November 3, 2026
Incident	IR1-2026-002, SEV-1 (contained in Task 3, evidence in Task 4, documented in Task 5)
Recovery run	19:40:22–19:48:53 UTC; snapshots before and after; validation run twice (before and after a reboot)
Result	Checklist 34/34 and 34/34; network probes 6/6 and 6/6; clock skew +0.0 s

Summary

Recovery did not try to clean the compromised host. The evidence was re-verified first, then the VM was returned to the clean snapshot taken before the incident. That snapshot is clean of attacker files but still has the conditions that let the incident happen: Tara's stale clinical group, no host firewall, open cron, leaver keys. Recovery therefore went on to **fix the root cause on the restored system**, restore the network and services, and prove the result with a 34-item checklist and six network probes, twice, with a reboot between. The root cause analysis traces the incident to a joiner/mover/leaver process that covered the identity provider but not local hosts. Five contributing factors and twelve improvements are listed, each with an owner and a due date.

1. How this report meets the Task 6 requirements

Requirement	Where	Evidence
Recovery procedure: VirtualBox environment restoration	§2.2	transcripts/02–03, snapshots
Recovery procedure: Parrot OS system recovery	§2.3	lab/recover_harden.sh, transcripts/04
Recovery procedure: network configuration recovery	§2.4	transcripts/04, validation/firewall_baseline_rules.v4
RCA: event timeline	§3.1	task4 timeline/ (176 events)
RCA: contributing factors	§3.2–3.3	5 Whys, factor table
RCA: technical findings from Parrot OS tools	§3.4	Volatility, Sleuth Kit, auditd, tcpdump outputs
Recovery validation checklist with testing procedures, created and implemented	§4	lab/validate_recovery.sh, validation/*.tsv
IR process improvement recommendations from lessons learned	§5	§5.1–5.3

2. Recovery procedures

2.1 Strategy

Option	When to use	Decision for IR1-2026-002
Clean in place (delete the attacker's files)	Never for a compromised host: you cannot prove you found everything	**Rejected**
Restore the last known-good snapshot	A snapshot from before the incident exists and its integrity is known	**Chosen**: baseline-clean (taken 19:22 UTC in Task 1, before the first user login)
Rebuild from the golden image	No trusted snapshot, or the snapshot may contain the attacker	Fallback: golden image hash verified (§2.2 step 3)

Key point: Whatever the choice, a known-good state is only as good as the configuration it holds. The baseline snapshot was taken after provisioning, so it contains the incident's root cause (Tara's clinical group). Restoring is step one; fixing is step two.

2.2 VirtualBox environment restoration

#	Step	VirtualBox command	Lab (executed)	Result
1	Evidence gate: re-verify everything before destroying the compromised state	(none)	shasum -c on the Task 3 and Task 4 indexes	task1 15/15, task2 24/24, task3 27/27, task4 64/64, large 5/5
2	Record the compromised state	snapshot take pre-recovery --live	HMP savevm pre-recovery	kept for reference
3	Verify the rebuild source	sha256 of the golden VDI/OVA	shasum golden.qcow2 vs recorded	MATCH
4	Restore the clean snapshot	snapshot <vm> restore baseline-clean	HMP loadvm baseline-clean	guest agent up
5	Production wiring: adapter 1 in, adapter 2 out	controlvm setlinkstate1 on; setlinkstate2 off	QMP set_link nic0 on / nic1 off	§2.4
6	Fix, validate, reboot, validate (§2.3, §4)	(none)	recover_harden.sh, validate_recovery.sh	34/34
7	New known-good baseline	snapshot take recovered-validated --live	HMP savevm recovered-validated	done

transcripts/01_r0_evidence_gate.txt

```
task1_check: 15 OK, 0 not OK
task2_check: 24 OK, 0 not OK
task3_check: 27 OK, 0 not OK
task4_check: 64 OK, 0 not OK
large_items_check: 5 OK, 0 not OK
IR1-2026-002_parrot-vm.mem.elf: OK
IR1-2026-002_syncd.core: OK
IR1-2026-002_parrot-vm_seized.raw: OK
IR1-2026-002_vda.dd: OK
parrot-vm_baseline.mem.elf: OK
GATE PASSED: evidence preserved - recovery may proceed
```

Snapshot inventory after recovery (transcripts/07)

```
List of snapshots present on all disks:
ID        TAG               VM SIZE                DATE     VM CLOCK     ICOUNT
--        baseline-clean    501 MiB 2026-11-03 19:22:59 00:06:18.221
--        ir-pre-containment  556 MiB 2026-11-03 19:31:26 00:14:44.476
--        ir-contained      596 MiB 2026-11-03 19:35:46 00:18:57.579
--        pre-recovery      598 MiB 2026-11-03 19:41:00 00:24:11.025
--        recovered-validated  952 MiB 2026-11-03 19:48:48 00:13:55.851
[2026-11-03T19:48:53Z] >>> done
evidence index: 19 files
```

2.3 Parrot OS system recovery

Right after the restore, the host was clean of the attacker's artifacts but showed the root cause again:

transcripts/03_r2_restore.txt

```
# what the restored host looks like BEFORE fixes: clean of artifacts, but the root cause is back
ls: cannot access '/home/test.nurse/.cache': No such file or directory
no crontab for test.nurse
uid=1003(test.nurse) gid=1006(test.nurse) groups=1006(test.nurse),1001(clinical),1002(billing)
test.nurse L 2026-11-03 0 99999 7 -1
-P INPUT ACCEPT
-P FORWARD ACCEPT
-P OUTPUT ACCEPT
```

Section	Fix (lab/recover_harden.sh)	Why
R2.1 Identity	`gpasswd -d test.nurse clinical`; `gpasswd -d test.clinician sudo`; keep test.nurse disabled pending HR; move authorized_keys off disabled accounts (test.nurse, test.billing)	Root cause of IR1-2026-002; leaver finding of IR1-2026-001
R2.2 Persistence	`/etc/cron.allow` = root	Users can no longer plant cron jobs
R2.3 Firewall	Default DROP in and out; SSH only from admin net 10.78.50.0/24; portal only from clinical LAN; egress DNS/NTP/DHCP/HTTP(S) only; IOC chain; loaded at boot by `ir-firewall.service`	The host had no firewall; the uploader used a non-standard port
R2.4 Services	unmask + enable cron, ehr-portal; remove the containment sshd drop-in	Back to normal service
R2.5 Audit	keep the incident watches; add `-w /etc/sudoers.d -k sudoers`	IR1-2026-003 (unapproved sudo) becomes visible

transcripts/04 (R2.1-R2.2)

```
== R2.1 identity: apply the JML register correctly (CHG-2026-0201 mover, TERM-2026-0301 leaver)
Removing user test.nurse from group clinical
Removing user test.clinician from group sudo
uid=1003(test.nurse) gid=1006(test.nurse) groups=1006(test.nurse),1002(billing)
uid=1004(test.billing) gid=1007(test.billing)
    groups=1007(test.billing),1002(billing),1003(disabled-users)
test.nurse L 2026-11-03 0 99999 7 -1
test.billing L 2026-11-03 0 99999 7 -1
== R2.2 persistence vector: only root may use cron (users cannot create crontabs)
total 8
drwx-wx--T 2 root crontab 4096 Mar  2  2023 .
drwxr-xr-x 3 root root    4096 Nov  3 00:10 ..
```

2.4 Network configuration recovery

- **Adapters** (hypervisor): clinical adapter cable in, quarantine adapter cable out.
- **Interfaces** (guest): quarantine interface flushed and down; `netplan apply` brings the clinical interface up with DHCP (10.0.2.15/24, gateway 10.0.2.2, DNS 10.0.2.3).
- **Firewall**: `/etc/iptables/rules.v4` restored at boot by a oneshot unit before the network comes up (rules below).
- **Time**: after the restore the guest clock was at snapshot time, -1096.0 s behind. `timedatectl` still said ‘System clock synchronized: yes’, a stale flag carried in the snapshot, while the RTC line showed the correct time. systemd-timesyncd corrected it before validation (skew +0.0 s). Lesson: measure the offset; don't trust the flag.

Interfaces and routes after recovery (transcripts/04)

```
clinical=enp0s1 quarantine=enp0s2
lo               UNKNOWN        00:00:00:00:00:00 <LOOPBACK,UP,LOWER_UP>
enp0s1           UP             52:54:00:0a:00:10 <BROADCAST,MULTICAST,UP,LOWER_UP>
enp0s2           DOWN           52:54:00:0a:00:50 <BROADCAST,MULTICAST>
lo               UNKNOWN        127.0.0.1/8 ::1/128
enp0s1           UP             10.0.2.15/24 metric 100 fec0::5054:ff:fe0a:10/64
    fe80::5054:ff:fe0a:10/64
enp0s2           DOWN
default via 10.0.2.2 dev enp0s1 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev enp0s1 proto kernel scope link src 10.0.2.15 metric 100
10.0.2.2 dev enp0s1 proto dhcp scope link src 10.0.2.15 metric 100
10.0.2.3 dev enp0s1 proto dhcp scope link src 10.0.2.15 metric 100
```

validation/firewall_baseline_rules.v4 - the persistent host firewall

```
# Care Access Navigator - parrot-vm host firewall baseline (post-incident IR1-2026-002)
*filter
:INPUT DROP [0:0]
:FORWARD DROP [0:0]
:OUTPUT DROP [0:0]
:IOC-BLOCK - [0:0]
-A IOC-BLOCK -m limit --limit 20/min -j LOG --log-prefix "IOC-BLOCK " --log-uid
-A IOC-BLOCK -j DROP
-A INPUT -i lo -j ACCEPT
-A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
-A INPUT -p tcp --dport 22 -s 10.78.50.0/24 -j ACCEPT
-A INPUT -p tcp --dport 8080 -s 10.78.10.0/24 -j ACCEPT
-A INPUT -m limit --limit 20/min -j LOG --log-prefix "FW-DENY-IN "
-A OUTPUT -d 10.78.99.66/32 -j IOC-BLOCK
-A OUTPUT -o lo -j ACCEPT
-A OUTPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
-A OUTPUT -p udp --dport 53 -j ACCEPT
-A OUTPUT -p tcp --dport 53 -j ACCEPT
-A OUTPUT -p udp --dport 123 -j ACCEPT
-A OUTPUT -p udp --dport 67:68 -j ACCEPT
-A OUTPUT -p tcp -m multiport --dports 80,443 -j ACCEPT
-A OUTPUT -d 10.78.50.20/32 -p tcp -m multiport --dports 1514,1515 -j ACCEPT
-A OUTPUT -m limit --limit 20/min -j LOG --log-prefix "FW-DENY-OUT " --log-uid
COMMIT
```

3. Root cause analysis

3.1 Event timeline

UTC	T+	Event
19:31:06	+0:00:00	Tara Jones logs in from the Mac (key-based SSH)
19:31:08	+0:00:02	Reads PT-1003 through the clinical group left over from her move
19:31:09	+0:00:03	Stages the record, starts syncd.py
19:31:10	+0:00:04	First copy reaches the drop site
19:31:11	+0:00:05	Adds a */5 cron job to restart the uploader
19:31:10	+0:00:04	Wazuh rule 100221 alert (SEV-1); containment starts
19:31:56	+0:00:50	Last copy reaches the drop site (10 in total)
19:31:59	+0:00:53	Egress blocked (C3)
19:32:52	+0:01:46	Host isolated (C6)
19:35:47	+0:04:41	Contained
19:41:09	+0:10:03	Restored to baseline-clean (eradication)
19:48:48	+0:17:42	Recovered and validated

Measure	Value
Attack to detection (first record read → detection)	1 s
Detection to egress block	49 s
Detection to contained	4.6 min
Detection to recovered and validated	18 min (includes Task 4 evidence work)
Copies disclosed	10 (one record)

3.2 Five whys

Why?	Answer	Evidence
1. Why did the record leave the host?	A process run by test.nurse uploaded it to 10.78.99.66 every 5 s	pcap 21 POSTs; Volatility sockstat; kern.log UID=1003
2. Why could test.nurse read the record?	She was still in the clinical group, which the EHR viewer trusts	ehr-audit basis=group:clinical; /etc/group
3. Why was she still in clinical?	Her mover change added Billing on the host but removed nothing	auth.log usermod add 'billing' only; JML-LOG CHG-2026-0201
4. Why did the mover step not remove it?	The JML process ran in Entra ID and Keycloak (which removed Nurse automatically) but local host groups were never part of it	JML-09 evidence; Task 2 §7

Why?	Answer	Evidence
5. Why were hosts outside JML?	Identity was designed IdP-first; local accounts were treated as lab setup, with no owner and no reconciliation	design doc v1.2; no host reconciliation job

Root cause: Access changes for movers were applied at the identity provider but not on Linux hosts, and nothing reconciled the two. A user whose role changed kept the old role's access on the host.

3.3 Contributing factors

Area	Factor	Effect on this incident
Process	No host access reconciliation; access review not run on hosts (finding F-05)	The mover change added Billing on the host and removed nothing; no step compared host groups with the IdP
Technology	No host firewall; no egress filtering	Uploads to an unknown host on port 8080 were allowed
Technology	Any user could create cron jobs	Persistence in one command
Identity	Disabled accounts kept SSH keys; passwd -S 'L' looked like locked	Leaver path open (IR1-2026-001); false sense of safety
Detection / response	The alert was automatic but containment was run by hand	49 s from alert to block; 10 copies out. Auto-block on alert + outbound would cut this to seconds

3.4 Technical findings from the Parrot OS tools

Tool	Finding	Significance
auditd / ausearch	34 commands by test.nurse, 19:31:07–19:31:11: ehr-view PT-1003, copy to ~/.cache/.sync, python3 syncd.py, crontab	Intent: the whole chain took 4.7 s, so it was scripted and planned
tcpdump / tshark	10 HTTP POSTs, User-Agent syncd/0.3, 127 bytes each, none after the block	Proves volume and that containment worked
iptables (LOG --log-uid)	Every dropped packet tagged UID=1003	Attribution from the firewall itself
gdb gcore + strings	Process memory holds the MRN, the file path and the URL	Proves the process held the data
Volatility 3	PID 1534: SSH_CONNECTION=10.78.10.1; socket SYN_SENT to the IOC; no hidden modules, no syscall hooks, malfind clean	Ties the process to the SSH session; rules out a rootkit
Sleuth Kit	syncd.py inode 32027, uid 1003, created 19:31:09; files hash-identical to the live copies	Disk agrees with memory and logs
timeline + sshd VERBOSE	5/5 Mac sessions matched to Parrot logins by key fingerprint, < 1 s apart	The actions came from that Mac, with that key

4. Recovery validation checklist

`lab/validate_recovery.sh` is the checklist written as code: each line is one test with an expected value, so it runs the same way every time and leaves a PASS/FAIL record. It runs inside the guest over the guest agent; `run_task6.sh` adds six network probes from the other machines. The whole set ran twice, before and after a reboot, to prove the fixes survive a restart.

ID	Check	Testing procedure	Expected	Run 1	Run 2
INT-01	OS package files unmodified (dpkg -V, non-config; Wazuh agent state excluded)	`dpkg -V 2>/dev/null | awk '$2 != "c"' | grep -vc ' /var/ossec/'`	0	**PASS**	**PASS**
INT-01b	Wazuh agent binaries unmodified (dpkg -V, /var/ossec/bin)	`dpkg -V wazuh-agent 2>/dev/null | grep -c ' /var/ossec/bin/'`	0	**PASS**	**PASS**
INT-02	staged record / uploader folder absent	`yn 'test -e /home/test.nurse/.cache/.sync'`	no	**PASS**	**PASS**
INT-03	no user crontabs in /var/spool/cron/crontabs	`ls /var/spool/cron/crontabs 2>/dev/null | wc -l`	0	**PASS**	**PASS**
INT-04	no syncd.py process	`pgrep -fc '^python3 .*[s]yncd'`	0	**PASS**	**PASS**
INT-05	no SUID/SGID files in user-writable paths	`find /home /tmp /var/tmp /dev/shm -xdev \( -perm -4000 -o -perm -2000`	0	**PASS**	**PASS**
IAM-01	test.nurse NOT in clinical (mover rule)	`yn 'id -nG test.nurse | tr " " "\n" | grep -qx clinical'`	no	**PASS**	**PASS**
IAM-02	test.nurse locked + expired (pending HR)	`passwd -S test.nurse | awk '{print $2}') $(chage -l test.nurse | awk -`	L 1970-01-02	**PASS**	**PASS**
IAM-03	test.billing (leaver) locked + expired	`passwd -S test.billing | awk '{print $2}') $(chage -l test.billing | a`	L 1970-01-02	**PASS**	**PASS**
IAM-04	no SSH keys on disabled accounts	`ls /home/test.nurse/.ssh/authorized_keys /home/test.billing/.ssh/autho`	0	**PASS**	**PASS**
IAM-05	sudo group = it_admin only	`getent group sudo | cut -d: -f4`	it_admin	**PASS**	**PASS**
IAM-06	clinician can still view a record (no over-correction)	`su / setpriv + ehr-view`	0	**PASS**	**PASS**
IAM-07	billing role is denied clinical record PT-1003	`su / setpriv + ehr-view`	1	**PASS**	**PASS**

ID	Check	Testing procedure	Expected	Run 1	Run 2
IAM-08	users other than root cannot use cron	`cat /etc/cron.allow 2>/dev/null | paste -sd,`	root	**PASS**	**PASS**
SVC-ssh	ssh active + enabled at boot	`systemctl is-active / is-enabled`	active enabled	**PASS**	**PASS**
SVC-cron	cron active + enabled at boot	`systemctl is-active / is-enabled`	active enabled	**PASS**	**PASS**
SVC-ehr-portal	ehr-portal active + enabled at boot	`systemctl is-active / is-enabled`	active enabled	**PASS**	**PASS**
SVC-auditd	auditd active + enabled at boot	`systemctl is-active / is-enabled`	active enabled	**PASS**	**PASS**
SVC-rsyslog	rsyslog active + enabled at boot	`systemctl is-active / is-enabled`	active enabled	**PASS**	**PASS**
SVC-ir-firewall	ir-firewall active + enabled at boot	`systemctl is-active / is-enabled`	active enabled	**PASS**	**PASS**
SVC-wazuh-agent	wazuh-agent active + enabled at boot	`systemctl is-active / is-enabled`	active enabled	**PASS**	**PASS**
NET-01	clinical NIC enp0s1 up with 10.0.2.15/24	`ip -br addr show $IF0 | awk '{print $2, $3}'`	UP 10.0.2.15/24	**PASS**	**PASS**
NET-02	default route via clinical NAT gateway	`ip route show default | awk '{print $3, $5}' | head -1`	10.0.2.2 enp0s1	**PASS**	**PASS**
NET-03	quarantine NIC enp0s2 has no address	`ip -br -4 addr show $IF1 | awk '{print $3}'`	(empty)	**PASS**	**PASS**
NET-04	firewall policies INPUT/FORWARD/OUTPUT = DROP	`iptables -S | grep -cE '^-P (INPUT|FORWARD|OUTPUT) DROP'`	3	**PASS**	**PASS**
NET-05	egress to IOC 10.78.99.66:8080 blocked	`curl -s -m 5 -o /dev/null -w '%{http_code}' http://10.78.99.66:8080/`	000	**PASS**	**PASS**
NET-06	egress HTTP for updates allowed	`curl -s -m 10 -o /dev/null -w '%{http_code}' http://deb.debian.org/deb`	200	**PASS**	**PASS**
NET-07	DNS resolution works	`yn 'getent hosts deb.debian.org'`	yes	**PASS**	**PASS**
NET-08	clock synchronised by NTP	`timedatectl show -p NTPSynchronized --value`	yes	**PASS**	**PASS**
MON-01	auditd incident watches loaded (5 keys)	`auditctl -l | grep -oE '(-k |key=)(ehr-read|cron-persist|identity|user`	5	**PASS**	**PASS**

ID	Check	Testing procedure	Expected	Run 1	Run 2
MON-02	EHR audit logged the clinician view (IAM-06)	`yn 'tail -5 /var/log/ehr-audit.log | grep -q "user=test.clinician acti`	yes	**PASS**	**PASS**
MON-03	EHR audit logged the billing denial (IAM-07)	`yn 'tail -5 /var/log/ehr-audit.log | grep -q "user=test.nurse action=V`	yes	**PASS**	**PASS**
MON-04	firewall logged the IOC block (NET-05)	`sleep 1; yn 'dmesg | tail -20 | grep -q IOC-BLOCK'`	yes	**PASS**	**PASS**
MON-05	Wazuh agent connected to the manager	`grep -oE "status='[a-z]+'" /var/ossec/var/run/wazuh-agentd.state | cut`	connected	**PASS**	**PASS**

ID	Network probe (from another host)	Expected	Run 1	Run 2
V-P1	macOS host -> parrot-vm SSH (user network)	BLOCKED	**BLOCKED**	**BLOCKED**
V-P2	clinical LAN -> parrot-vm SSH	BLOCKED	**BLOCKED**	**BLOCKED**
V-P3	clinical LAN -> EHR portal :8080 (service restored)	REACHABLE	**REACHABLE**	**REACHABLE**
V-P4	admin network 10.78.50.0/24 -> parrot-vm SSH	REACHABLE	**REACHABLE**	**REACHABLE**
V-P5	quarantine path :2222 closed	BLOCKED	**BLOCKED**	**BLOCKED**
V-P6	parrot-vm -> IOC drop site	BLOCKED	**BLOCKED**	**BLOCKED**

Checklist defects found and fixed: Test runs of the checklist before this exercise found three defects in the checklist itself, not in the host. `pgrep -f syncd.py` matched the checklist's own command line. The audit-rule count looked for `key=`, while `auditctl -l` prints watches as `-k`. And `dpkg -V` flagged 264 files that the Wazuh agent legitimately rewrites in its own folder, so the check was split into INT-01 (OS packages) and INT-01b (agent binaries). A checklist needs testing too.

Reboot before run 2 (transcripts/06) - the guest agent never answers a shutdown command, so the TimeoutError is expected

```
# R6 reboot, then repeat every check (proves the fixes persist)
TimeoutError: timed out
guest agent: up
 19:46:57 up 1 min,  0 user,  load average: 2.74, 0.92, 0.33
running
status='connected'
```

5. Lessons learned and IR process improvements

5.1 What went well

- Wazuh raised rule 100221 1 s after the record was read, and egress was blocked 49 s after the alert. The rule was built and tested in Task 1 for exactly this event.
- Monitoring never stopped: the Wazuh agent kept reporting through the quarantine forward during isolation, and again from the recovered host.
- Order of volatility held. The uploader's memory, sockets and packets were captured before it was killed, and that memory later answered questions the logs could not.
- Every evidence item was hashed at both ends and re-verified three times (Task 4 intake, Task 4 report, Task 6 gate) with no mismatch.
- Snapshots made every risky step reversible and gave a clean recovery point.

5.2 What did not go well

Problem found while building and running the response	Impact	Fix now in the procedure
Firewall allow-rule written for the NAT gateway address; the hypervisor forwards the real client IP	Forensic SSH blocked after isolation (first run)	Playbook: test the allow path before setting DROP
Live logs hashed before copying; they changed in between	2 hash mismatches (first run)	Freeze to RAM (cp -a), then hash and copy
Guest CPU used 5-level paging	Volatility found no processes	VM template: LA57 off; note in tools guide
dc3dd will not write to a pipe or FIFO	Live imaging over SSH failed	Seize at hypervisor, image read-only on the workstation
auditd serials restart at boot	Wrong times on the first timeline	Join on time + serial
Isolated host lost NTP (75 min slow in an earlier test run); stale 'synchronized' flag after restore	Timestamps misleading without a reference	Measure offset against the workstation at every step
Recovery checklist had 3 defects (self-match, -k vs key=, agent state files)	False FAILs in test runs	Test the checklist on a known-good host first
The Mac slept during a test run	Scenario paused 8 min; packet capture window expired	Keep the analyst workstation awake (caffeinate) for the whole response
Wazuh log collector exited under emulation	macOS lines lost in a test run	ship_file: check the collector after every batch, restart and resend; count sent vs received
'Agent Active' read before the agent had reconnected	False confidence in monitoring	Wait for the agent's own 'Connected to [quarantine forward]' line
Validation started before the restored agent reconnected (test run)	MON-05 failed on run 1	Wait for agent status 'connected' before the checklist runs

5.3 Improvement plan

#	Improvement	Type	Owner	Due	Measure of success
1	Reconcile host groups and SSH keys with the IdP nightly; extend the JML runbook to hosts	Process	IAM owner	2026-11-16	0 stale groups in the nightly report
2	Mover access review at 30/60/90 days (closes F-05)	Process	IAM owner	2026-11-30	100% of movers reviewed
3	Roll out the host firewall baseline (egress allow-list) to every EHR host	Technology	System owner	2026-11-16	All hosts pass NET-04/05
4	cron.allow = root fleet-wide	Technology	System owner	2026-11-16	INT-03/IAM-08 pass everywhere
5	Auto-containment: rule 100221 + outbound connection triggers RB-02 C3 (Wazuh active response)	Detection	Security lead	2026-12-15	Block < 10 s in the next exercise
6	Alert on any new outbound destination from EHR hosts	Detection	Security lead	2026-12-15	Alert in exercise replay
7	Lock = expire + remove keys in the leaver step (not passwd -l alone)	Process	IAM owner	2026-11-09	IAM-03/04 pass on all hosts
8	Every sudo grant needs a change record and an expiry (IR1-2026-003)	Process	IT admin	2026-11-16	0 grants without a ticket
9	VM template: LA57 off, guest agent, NIC trace on, snapshot policy	Technology	IR analyst	2026-11-09	Volatility works on next dump
10	Time: quarantine network gets an NTP source; offset logged at every IR step	Process	IR analyst	2026-11-09	Skew < 1 s in reports
11	Run validate_recovery.sh after every change to an EHR host	Process	System owner	ongoing	34/34 on each run
12	Repeat this exercise every 6 months; update CAN-IR-PB-02	Governance	IR analyst	2027-05-02	Playbook version bump

Link to the project: Items 1–2 and 7–8 also close project audit findings (F-05 access review). The live Keycloak findings F-01 (MFA), F-02 (lockout) and F-04 (password policy) are outside this host incident and are still open on the project board.

6. Limitations

- VirtualBox and Parrot OS are substituted by QEMU and a Debian 12 VM; each step lists its VirtualBox command (Task 3 §2).
- test.nurse stays disabled: whether to restore her Billing-only access is an HR decision (recorded as D3), not a technical one.
- Recovery was validated on one host. Items 3–4 of the plan apply the same baseline to the others.